Vitest browser mode serves unsanitized otelCarrier query parameter as inline script

Report Type: Weekly · Generated: June 01, 2026 14:50 UTC · Coverage: Jun 01 – Jun 01, 2026

1 Total Advisories	1 Critical	0 High	0 Medium
CRITICAL Severity	9.6 CVSS / Risk Score	TLP:CLEAR TLP Classification	PRO Customer Tier

Executive Summary

Summary Vitest browser mode served `/__vitest_test__/` with the `otelCarrier` query parameter inserted directly into an inline module script. Because this value was treated as JavaScript source rather than data, an attacker could craft a browser-runner URL that executes arbitrary JavaScript in the Vitest server origin. https://github.com/vitest-dev/vitest/blob/cba2036a197ec8ed42c35a37db78ef07192202c7/packages/browser/src/node/serverOrchestrator.ts#L48 https://github.com/vitest-dev/vitest/blob/cba2036a197ec8ed42c35a37db78ef07192202c7/packages/browser/src/client/public/esm-client-injector.js#L41 The same generated page embeds `VITEST_API_TOKEN`, which is used to authenticate Vitest WebSocket APIs. Script execution in this origin can therefore recover the token and make authenticated API calls. ## Impact This issue affects users running Vitest browser mode. A victim must open or navigate to a crafted Vitest browser-runner URL while the Vitest browser server is running. In the de

Top Threat Advisories

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

Advisory Title	Severity	CVSS	EPSS	AI Summary
Vitest browser mode serves unsanitized otelCarrier query parameter as	CRITICAL	9.6	—	## Summary Vitest browser mode served `/__vitest_test__/` with the `otelCarrie

MITRE ATT&CK® v15 Mapping

Technique density score: **0.0** · Techniques observed: **0** · Tactics covered: **0**

MITRE ATT&CK techniques pending analyst enrichment. Deploy detection rules from Section 6 to identify related activity.

Threat Actor Intelligence

Attribution analysis across advisories in this report period.

Threat Actor	Count	Associated CVEs / Indicators
CDB-UNATTR-CVE	1	—

Indicators of Compromise (IOCs)

IOC extraction for this advisory is pending enrichment pipeline completion. PRO subscribers receive real-time IOC push to SIEM/SOAR via the SENTINEL APEX webhook at: **GET /api/v1/intel/iocs?advisory={id}**. Full IOC packages include IPv4, domain, SHA256, and URL indicators with confidence scores, first-seen timestamps, and STIX 2.1 formatted bundles.

Detection Engineering

Deploy these production-ready detection rules into your SIEM platform to identify exploitation attempts in real time. Compatible with Microsoft Sentinel, Splunk ES, and any Sigma-compatible platform.

Sigma Rule — Webserver / Process Monitoring

```
title: SENTINEL APEX — CDB-ADVISORY Exploitation Attempt
id: cdb-cdb-advisory-det
status: experimental
description: Detects exploitation indicators related to CDB-ADVISORY.
references:
- https://intel.cyberdudebivash.com
author: CyberDudeBivash SENTINEL APEX
date: 2026/06/01
tags:
- attack.initial_access
- attack.t1190
logsource:
category: webserver
detection:
keywords:
- 'CDB-ADVISORY'
condition: keywords
falsepositives:
- Security testing / penetration testing
level: medium
```

Microsoft Sentinel — KQL Query

```
// SENTINEL APEX — Vitest browser mode serves unsanitized otelCarrier query parameter as inline script
// Advisory | Microsoft Sentinel KQL
let time_window = ago(24h);
SecurityAlert
| where TimeGenerated > time_window
| where Description has "Vitest browser mode serves unsanitized o"
or AlertName has "Vitest browser mode serves unsanitized o"
or ExtendedProperties has "Vitest browser mode serves unsanitized o"
| extend Rule = "APEX-ADVISORY", Severity = "CRITICAL"
| project TimeGenerated, AlertName, AlertSeverity, Entities, Description, Rule, Severity
| order by TimeGenerated desc
```

Incident Response Playbook

Phase 1 — 0–24 Hours (Containment)

1. Activate IR team; assign lead analyst and executive sponsor.
2. Isolate or WAF-shield Vitest browser mode serves unsanitized otelCarrier query parameter as inline script instances exposed to the internet.

3. Enable verbose access logging on all Vitest browser mode serves unsanitized otelCarrier query parameter as inline script endpoints immediately.
4. Pull last 72h of web server and application logs for forensic baselining.
5. Check SENTINEL APEX IOC feeds and SIEM alerts for exploitation hits in your environment.
6. Notify relevant internal stakeholders and legal / compliance team.

Phase 2 — 24–72 Hours (Eradication)

1. Apply vendor patch for Vitest browser mode serves unsanitized otelCarrier query parameter as inline script or implement recommended mitigation.
2. Deploy Sigma and KQL detection rules from Section 6 across all SIEM platforms.
3. Rotate all API keys, service account credentials, and session tokens.
4. Conduct forensic timeline reconstruction for potential compromise window.
5. Validate patch deployment across 100% of affected instances via asset inventory.

Phase 3 — 7 Days (Recovery & Hardening)

1. Conduct post-incident review and update incident response runbooks.
2. Threat hunt for lateral movement or persistence artifacts using MITRE ATT&CK mapping.
3. Update asset inventory with patched version information and closure evidence.
4. Submit findings to internal risk register and CISO dashboard.
5. Schedule follow-up vulnerability scan to confirm remediation completeness.

Financial Impact Analysis (FAIR Model)

$2.4M — $12M	$5.8M	$1.2M/day	$850K
Breach Cost Range (FAIR)	IBM Cost of Breach 2025 Median	Business Interruption Cost	Regulatory Fine Exposure

Critical severity breaches trigger mandatory 72-hour regulatory disclosure (GDPR Art. 33), class-action exposure, and long-tail legal costs averaging 18–36 months post-incident.

Remediation Cost Estimate: $380K · Includes engineering time, IR retainer activation, forensic investigation, and customer notification costs.

Regulatory & Compliance Implications

Organizations processing this advisory must evaluate obligations under applicable regulatory frameworks. The table below maps this threat to relevant compliance requirements.

Framework	Reference	Obligation
GDPR	Art. 33 / Art. 83(4)	72-hour breach notification to DPA; fines up to 4% of global annual turnover

Framework	Reference	Obligation
PCI-DSS v4.0	Req. 6.3 / 6.4	Critical patches within 1 month; compensating controls required
NIS2 Directive	Art. 23	Early warning within 24h; full incident report within 72h
SOX / ICFR	Section 302 / 404	Material cybersecurity weakness disclosure in 10-K/10-Q
ISO 27001:2022	A.8.8 / A.5.29	Documented vulnerability management and incident management

Actionable Recommendations

Prioritized defensive actions based on this period's intelligence.

1. Apply patches immediately for Vitest browser mode serves unsanitized otelCarrier query parameter as inline script.
2. Enable enhanced monitoring for related IOCs.
3. Review SIEM rules for associated MITRE ATT&CK techniques.
4. Apply vendor patch for Vitest browser mode serves unsanitized otelCarrier query parameter as inline script immediately — check NVD for official fix guidance.
5. Enable enhanced logging and alerting on all systems running affected software versions.
6. Deploy the Sigma detection rule from this report into your SIEM platform (Sentinel / Splunk / Elastic).
7. Audit all internet-facing instances of affected products and confirm patch deployment.

Appendix — Report Metadata & Legal

Field	Value
Report ID	intel--95e84400f059da698dba326d
Report Type	Weekly
Platform	CYBERDUDEBIVASH SENTINEL APEX v166.0 GOD-MODE
Generated At	2026-06-01T14:50:39.08926
Customer Tier	PRO
Customer Email	—
TLP	TLP:CLEAR
STIX Version	2.1
ATT&CK Version	v15

Legal & Usage Notice